

Secure Database Architecture

Ministry of Transport — Republic of Cameroon

Classification: RESTRICTED — Government Use Only

Reference: MOT-ISS-ARCH-2025-001 | Version 1.0 | May 2025

Compliance: Law No. 2024/017 on Personal Data Protection

Table of Contents

- [1. Overview & Design Philosophy](#)
- [2. Network Architecture — The Invisible Database](#)
 - [2.1 Why the Network Layer Matters](#)
 - [2.2 Peer-to-Peer Mesh VPN with NetBird](#)
 - [2.3 Mutual TLS \(mTLS\)](#)
- [3. Storage & Data Security](#)
 - [3.1 Encryption at Rest — Volume Level](#)
- [4. Just-In-Time Access for Admins](#)
 - [4.1 Why Permanent Credentials Are Dangerous](#)
 - [4.2 The JIT Workflow with HashiCorp Vault & Boundary](#)
- [5. Security Governance & Regulations](#)
- [6. Global Architecture — Full System View](#)
- [7. Scenario Analysis — Attack & Response Flows](#)
 - [7.1 Scenario A: External Attacker Scans the Database Port](#)
 - [7.2 Scenario B: Compromised Application Server](#)
 - [7.3 Scenario C: Rogue Admin with Stolen Credentials](#)
 - [7.4 Scenario D: Physical Disk Theft](#)
 - [7.5 Scenario E: Legitimate Admin Debug Session](#)
- [8. Implementation Roadmap](#)
- [9. Limitations & Constraints](#)

1. Overview & Design Philosophy

The Ministry of Transport database holds some of the most sensitive data in Cameroon: national identity linkages, driving licence records, vehicle ownership chains, and transport operator details. A breach does not only mean a data leak — it means potential identity fraud, falsified driving licences, and loss of public trust in government systems.

The architecture described in this document is built on a single governing principle:

Zero Trust, Data-Centric Security — assume the public internet is hostile, assume any single control can be bypassed, and design the system so that a breach of one layer reveals nothing useful to an attacker.

This is realised through four independent defence layers that stack on top of each other. An attacker must defeat all four simultaneously to reach plaintext data, which is practically infeasible:

Layer	What It Protects	Technology
L1 — Network Isolation	Makes the database invisible on the internet	Cloud Firewall + NetBird Mesh VPN
L2 — Transport Identity	Ensures only trusted apps can connect inside the VPN	Mutual TLS (mTLS)
L3 — Storage Encryption	Renders raw disk data unreadable without keys	LUKS FDE + TDE

Each layer is described in full detail below — what it is, why it is necessary, and exactly how it operates.

2. Network Architecture — The Invisible Database

2.1 Why the Network Layer Matters

The database server has a public IP address because it is hosted at a cloud provider. By default, this means that anyone on the internet can attempt to connect to it. Port scanners — tools that systematically probe IP addresses for open services — are run continuously by attackers around the world. If the database port (TCP 5432 for PostgreSQL) is visible, it will be found, and automated credential-stuffing and exploit attempts will begin within minutes.

The goal of the network layer is to make the database port completely invisible to the public internet while keeping it reachable only to the specific application servers that need it — even though those application servers live on different cloud providers.

The solution is a **private encrypted overlay network** built with NetBird, a modern Mesh VPN based on the WireGuard protocol.

2.2 Peer-to-Peer Mesh VPN with NetBird

What It Is

A Mesh VPN creates a virtual private network between a set of machines. Unlike traditional VPNs that route all traffic through a central gateway, a mesh VPN connects each machine directly to every other authorised machine in an encrypted peer-to-peer tunnel. NetBird uses **WireGuard** as its underlying protocol — a modern, audited, and extremely fast cryptographic VPN that operates over UDP.

Once the NetBird agent is installed on a machine, that machine receives a **private overlay IP address** (for example `100.64.0.x`). Communication between machines in the mesh happens over this private address space, fully encrypted, regardless of where those machines are physically hosted.

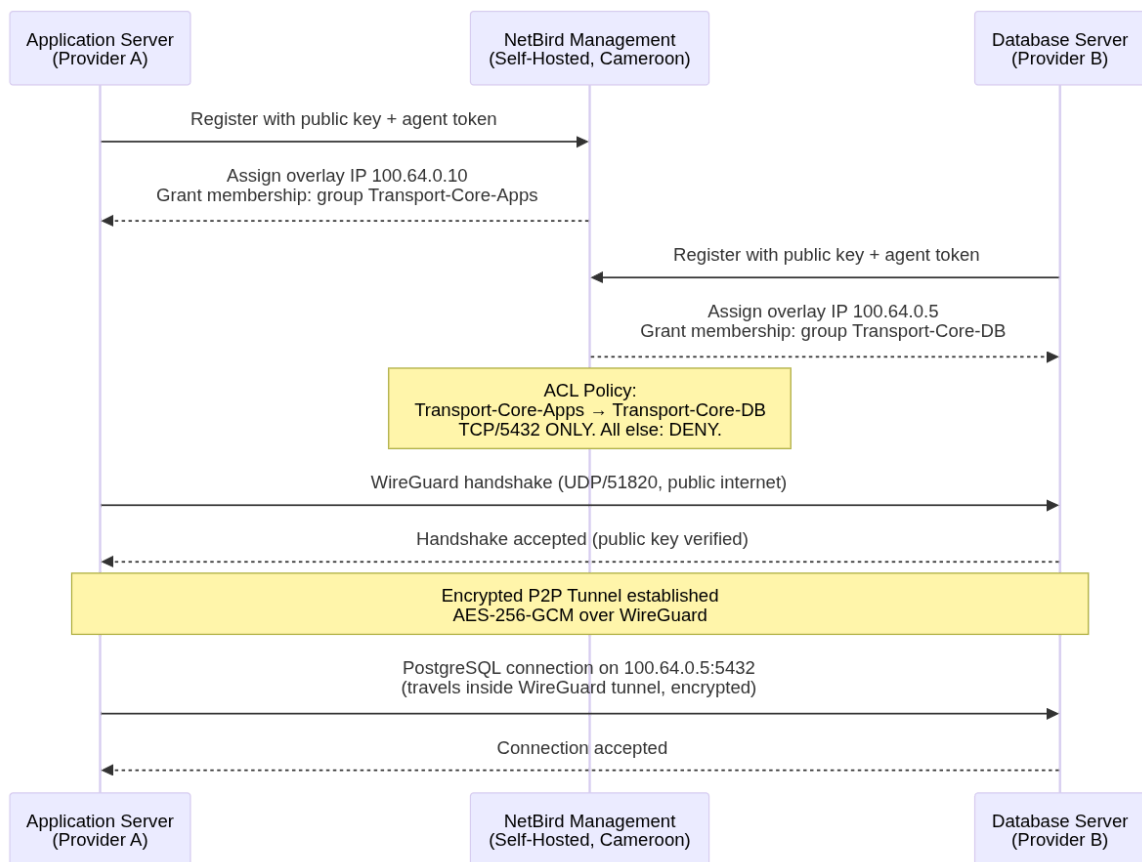
Why We Need It

Without a Mesh VPN, the only way for an application server on Provider A to reach the database on Provider B is over the public internet using the database's public IP — which exposes it to every attacker on the internet.

With NetBird:

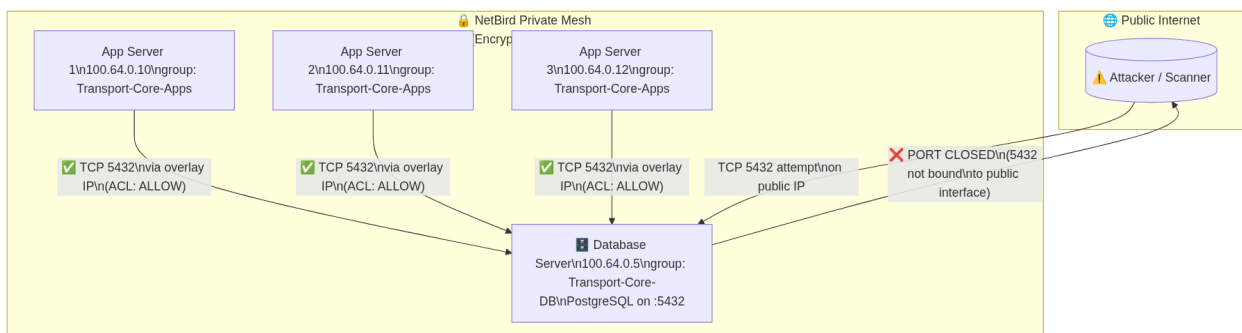
- The **database port is bound only to the private overlay IP** (e.g., `100.64.0.5`), not to the public IP.
- The **cloud firewall blocks all inbound traffic to the database** except the WireGuard UDP handshake port (UDP 51820). There is no rule that opens TCP 5432 to anyone.
- An attacker scanning the database's public IP will find nothing open except the WireGuard port, which does not respond to unauthorized peers.
- Application servers authenticate with the NetBird management server using their public keys and are issued a private overlay IP. Only enrolled, authorised machines can join the mesh.

How It Functions — Step by Step



Network Access Control — ACL Policy

NetBird enforces rules at the management level. The following policy governs who can talk to the database:



Result: The database is effectively invisible. Its public IP exists but carries no exploitable service on any standard port. The database lives in a shadow network that only enrolled, authenticated machines can see.

2.3 Mutual TLS (mTLS)

What It Is

TLS (Transport Layer Security) is the protocol that powers HTTPS — it encrypts a connection and lets a client verify the server's identity. **Mutual TLS (mTLS)** goes further: it requires **both sides to present and verify a certificate**. The server proves its identity to the client, and the client proves its identity to the server.

In the context of the database:

- The **database (server)** presents its certificate: the application knows it is talking to the real database, not an impersonator.
- The **application (client)** presents its certificate: the database knows it is talking to a trusted, registered application — not just any machine that happens to be inside the VPN.

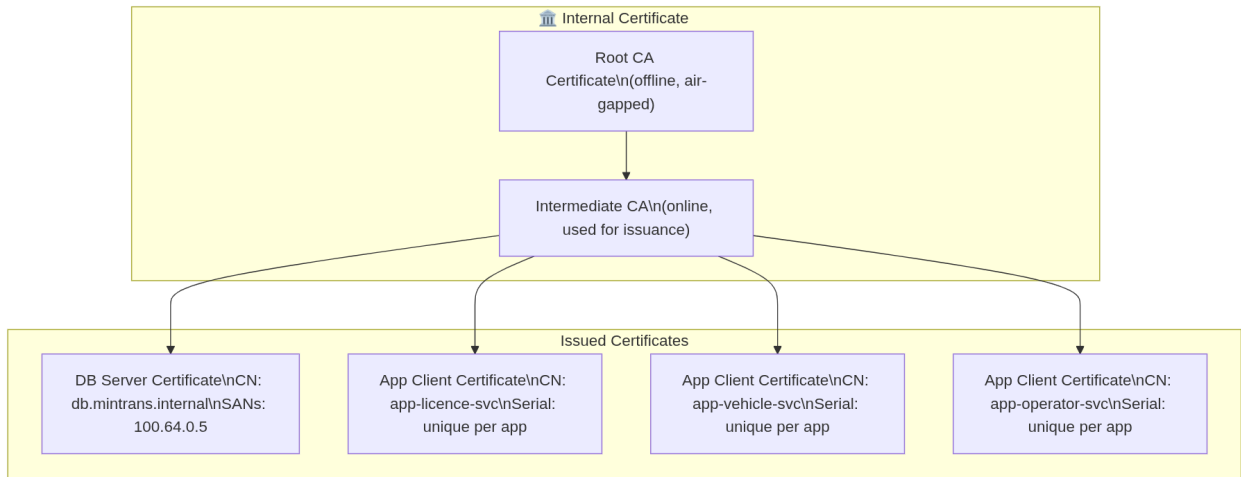
Why We Need It

The VPN layer (NetBird) controls **which machines** can reach the database at the network level. But it does not control **which processes or users** on those machines can authenticate to the database.

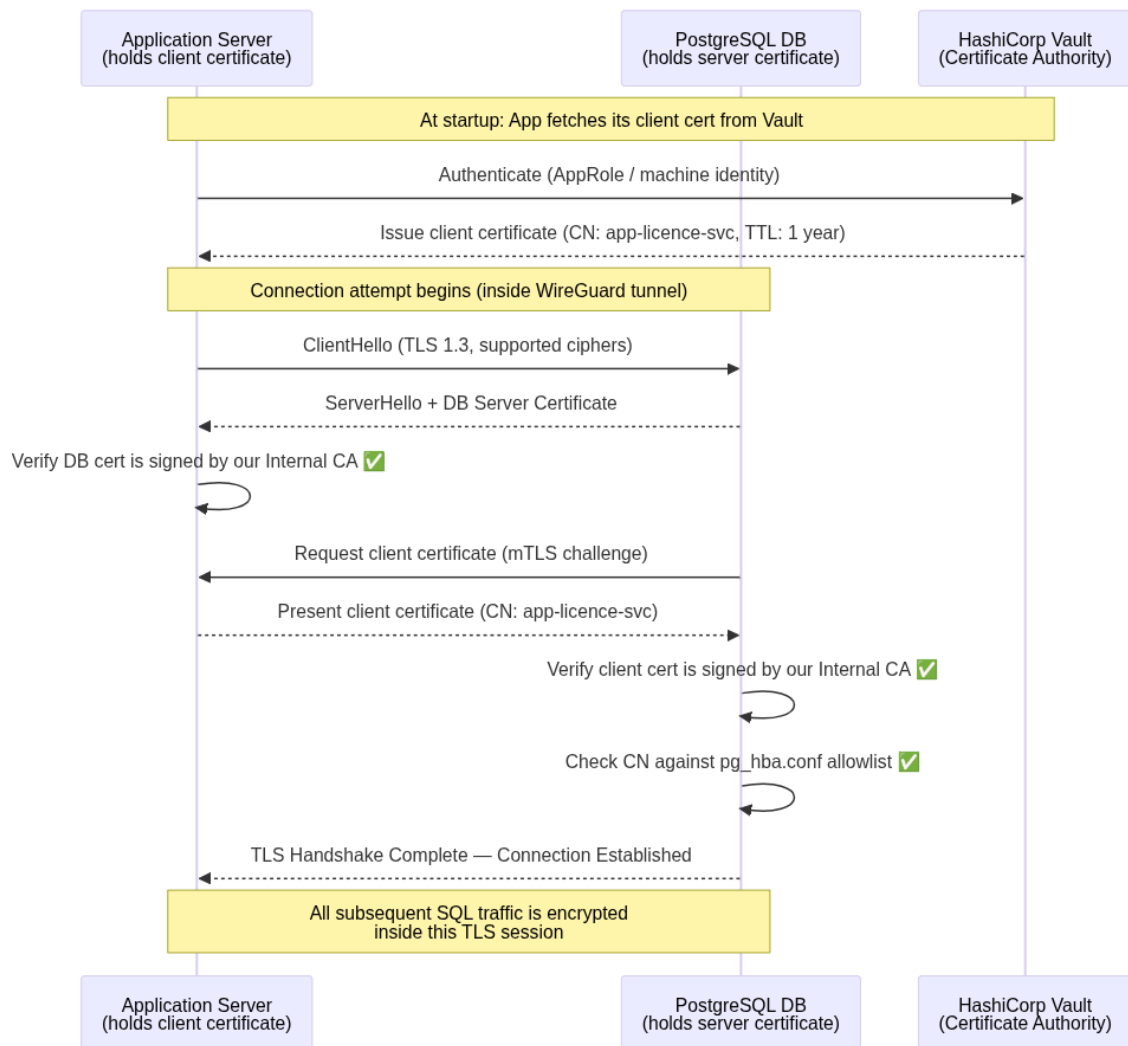
Consider this attack scenario: an application server is compromised, and an attacker gets a shell on it. They are now inside the VPN and can reach the database IP. Without mTLS, they could attempt to connect with any username/password combination. With mTLS, they cannot connect at all without presenting the application's private certificate — which is stored in a protected secret store (HashiCorp Vault or an HSM), not on the filesystem.

mTLS provides **cryptographic application identity**. A certificate cannot be guessed or brute-forced.

How mTLS Works — Certificate Chain



mTLS Handshake — Connection Flow



PostgreSQL Configuration

In `pg_hba.conf`, the database is configured to reject any connection that does not carry a valid client certificate:

```
# TYPE DATABASE USER ADDRESS METHOD
hostssl all app_licence_svc 100.64.0.0/24 cert
clientcert=verify-full
hostssl all app_vehicle_svc 100.64.0.0/24 cert
clientcert=verify-full
hostssl all app_operator_svc 100.64.0.0/24 cert
clientcert=verify-full
# All other connection attempts are rejected
host all all 0.0.0.0/0 reject
```

Result: Even if an attacker gains access to the VPN network and knows a valid database username, they **cannot connect** without the private key of the corresponding client certificate. The certificate's private key never leaves the Vault or HSM.

3. Storage & Data Security

Securing the network pipe is essential, but it is not enough. If an attacker gains access to the physical disk (through provider compromise, datacenter breach, or confiscation), the data must still be unreadable. This section describes three complementary layers of data-at-rest protection.

Storage Security — Three Layers

Layer 1: Volume Encryption (LUKS / CMK)\nEntire disk is encrypted at OS level\nAttacker with disk sees only ciphertext blocks



Layer 2: Transparent Data Encryption (TDE)\nDatabase engine encrypts its own files\nData files, WAL, temp files — all encrypted



Layer 3: Application-Level Encryption (ALE)\nMost sensitive fields encrypted BEFORE storage\nDB admin sees only ciphertext in rows

3.1 Encryption at Rest — Volume Level

What It Is

Volume encryption (Full-Disk Encryption / FDE) encrypts the entire storage volume at the block device level. Every byte written to disk — database files, logs, temp files, swap — is encrypted before it hits the physical medium. The encryption is handled by the OS kernel using **LUKS (Linux Unified Key Setup)** with the **AES-256-XTS** cipher.

Why We Need It

Cloud providers manage physical hardware. Their staff, legal processes in their jurisdiction, or a physical hardware recycling/replacement process could expose raw disk contents. Volume encryption ensures that the raw disk, if ever separated from the running system, is completely unreadable.

Additionally, Cameroon's Law No. 2024/017 on Personal Data Protection requires appropriate technical measures to protect personal data — volume encryption is the foundational technical measure.

How It Functions

When the system boots, it retrieves the LUKS decryption key from a secure key source (HashiCorp Vault's auto-unseal mechanism or a hardware HSM). The kernel decrypts disk reads and encrypts disk writes transparently. The PostgreSQL process, running on top, sees normal unencrypted data — but anything written to the physical medium is encrypted.

Customer-Managed Keys (CMK): If the cloud provider offers CMK, the master encryption key is held by the Ministry — not by the cloud provider. This means the provider cannot decrypt the volume even under a court order in their own jurisdiction. The Ministry retains full key sovereignty.

4. Just-In-Time Access for Admins

4.1 Why Permanent Credentials Are Dangerous

In traditional setups, administrators have a permanent database username and password. This creates several severe risks:

- **Stale credentials** — an admin who leaves the organisation may still have their credentials for days or weeks before anyone remembers to revoke them.
- **Credential theft** — a permanently valid password, if stolen, gives an attacker indefinite access.
- **No blast radius control** — a permanent admin account typically has broad privileges; a compromise of that account is a full breach.
- **No forced audit trail** — there is nothing forcing the admin's actions to be logged or reviewed before access is granted.

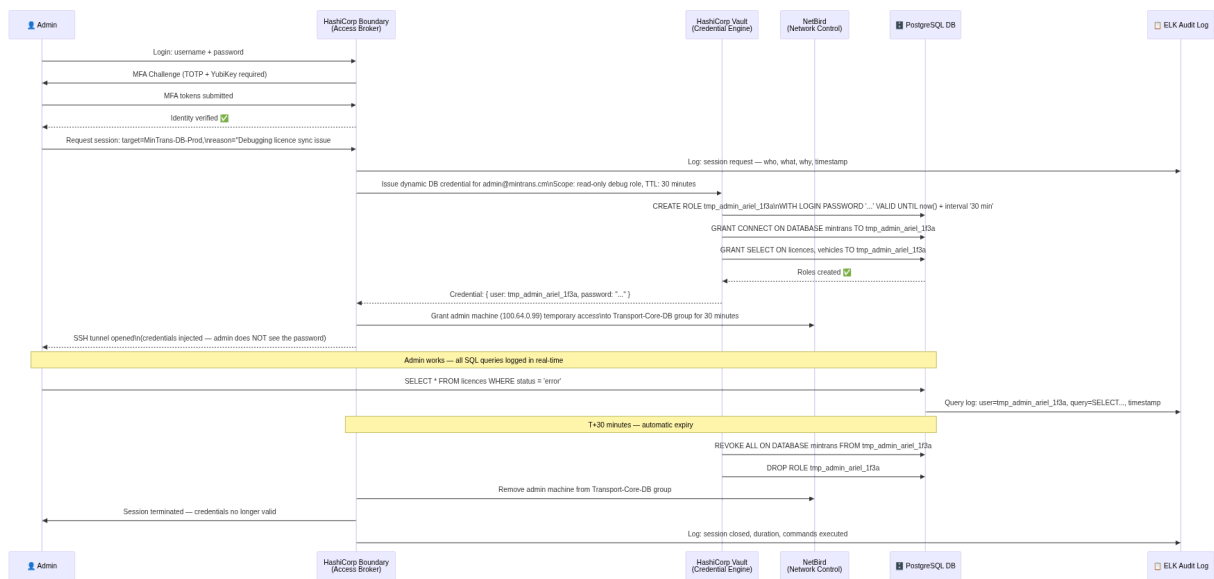
The solution is to eliminate all permanent human credentials to the production database. Humans access the database **only through a Just-In-Time (JIT) system** that generates short-lived, automatically-expiring credentials on demand.

4.2 The JIT Workflow with HashiCorp Vault & Boundary

The Components

Component	Role
HashiCorp Vault	Secret store and dynamic credential generator. Connects to PostgreSQL and creates/deletes temporary users on demand.
HashiCorp Boundary	Secure access broker. Controls who can request a session, enforces MFA, injects credentials into sessions (admins never see the password), and logs all activity.
NetBird Access Controls	The admin's machine is not in the <code>Transport-Core-DB</code> NetBird group by default — they cannot even reach the database IP unless a session is actively approved.
MFA	Multi-Factor Authentication (TOTP app + hardware key) is required to authenticate with Boundary before any credential can be issued.

The Full JIT Workflow



Access Permission Matrix

Actor	Network Access (NetBird)	DB Connection	Credential Type	TTL
Application servers	Permanent (group member)	mTLS client cert	Machine certificate	1 year (auto-renew)
Senior admin	JIT only (session-scoped)	Boundary-injected password	Dynamic Vault user	30 minutes
Junior admin / analyst	JIT only, read-only scope	Boundary-injected password	Dynamic Vault user	15 minutes
Emergency break-glass	HSM-sealed envelope procedure	Direct (last resort)	Static + senior approval	Single use

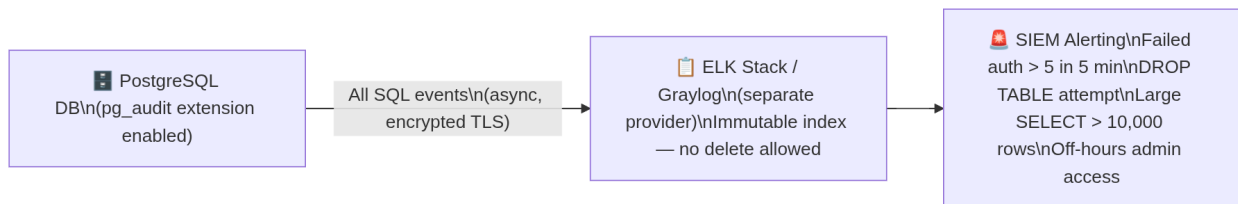
Result: At any given moment, there are zero permanent human credentials in existence for the production database. If an admin's laptop is stolen, there is nothing to steal — the credentials expired 30 minutes after the last session ended.

5. Security Governance & Regulations

Audit Logging

Every single SQL statement executed on the production database is forwarded to a remote, immutable log server. This server is on a **separate provider and separate network** — a compromised database server cannot tamper with its own audit trail.

The `pg_audit` extension is configured to capture all DML (SELECT, INSERT, UPDATE, DELETE) and DDL (CREATE, ALTER, DROP) statements, along with the executing user, timestamp, and source IP.



Principle of Least Privilege

No application user has any privilege beyond the minimum required for its function:

Application User	Allowed	Forbidden
<code>app_licence_svc</code>	SELECT, INSERT, UPDATE on <code>licences.*</code>	DROP, TRUNCATE, DELETE, EXPORT, <code>pg_dump</code>
<code>app_vehicle_svc</code>	SELECT, INSERT on <code>vehicles.*</code>	All writes beyond INSERT, DROP
<code>app_report_ro</code>	SELECT on reporting views only	All writes, schema access
<code>app_operator_svc</code>	SELECT, INSERT, UPDATE on <code>operators.*</code>	DROP, TRUNCATE, cross-schema access

Database Hardening

Hardening Measure	Implementation
Change default port	PostgreSQL listens on non-standard port (e.g., 54321) on the overlay IP only
Disable unused extensions	Remove all extensions not required by application
Non-privileged OS user	PostgreSQL process runs as <code>postgres</code> user, not root

Hardening Measure	Implementation
Connection limits	Max connections per user enforced; rate limiting on pg_hba
OS hardening	CIS Benchmark Level 2 applied; SSH key-only, no password auth

IP Whitelisting — Secondary Failsafe

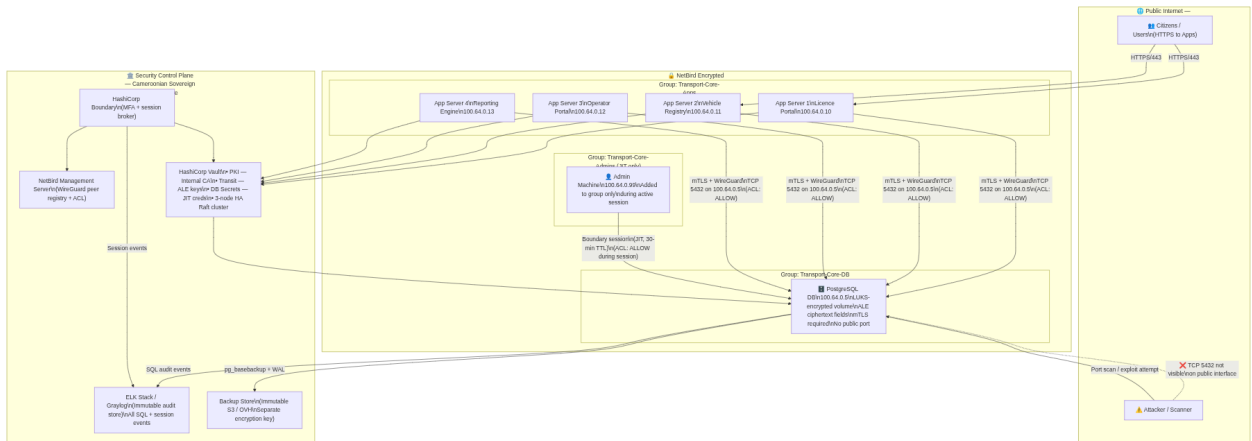
In addition to the NetBird overlay, cloud security groups are configured to allow the WireGuard port only from the known public IP ranges of the other cloud providers. This is a secondary, defence-in-depth measure — even if NetBird were to have a vulnerability, an attacker would also need to source their traffic from the correct provider IP range.

Data Residency & Legal Compliance (Law No. 2024/017)

- Physical servers hosting citizen personal data must be located within Cameroon or a jurisdiction with an adequacy agreement.
- All security tools (NetBird management, Vault, ELK) are self-hosted on Cameroonian or sovereign infrastructure — no government keys or logs pass through external SaaS platforms.
- Breach notification to the national data protection authority within **72 hours** of detection.
- Data minimisation: applications must not use `SELECT *` — column-level grants enforce access to only necessary fields.

6. Global Architecture — Full System View

This diagram shows every component of the architecture and how they relate. Read it as three zones: the public internet (hostile), the NetBird private mesh (trusted but verified), and the security control plane (the nerve centre).

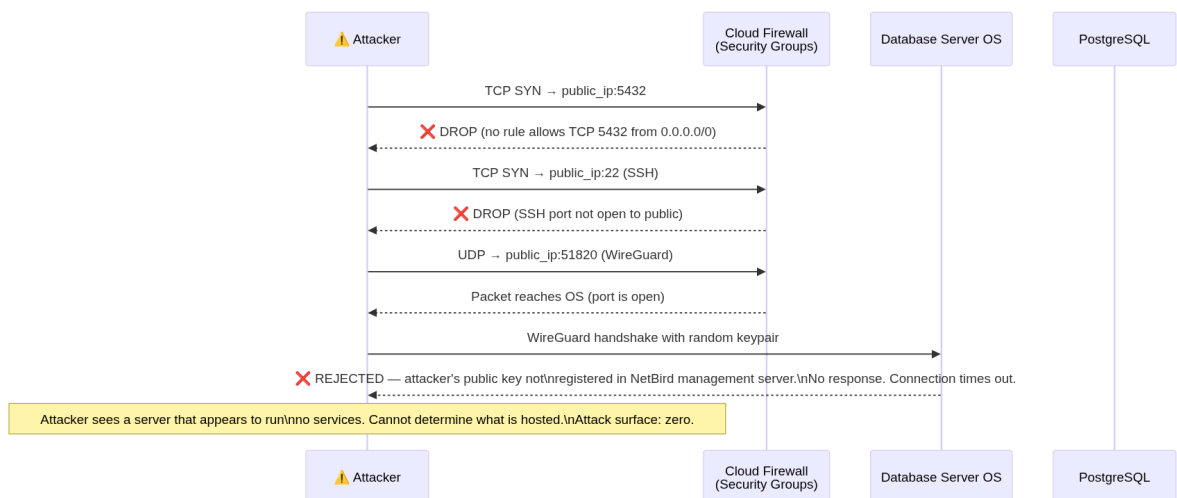


7. Scenario Analysis — Attack & Response Flows

This section walks through five concrete scenarios: four attack scenarios and one legitimate access scenario. Each shows how the architecture intercepts and neutralises the threat.

7.1 Scenario A: External Attacker Scans the Database Port

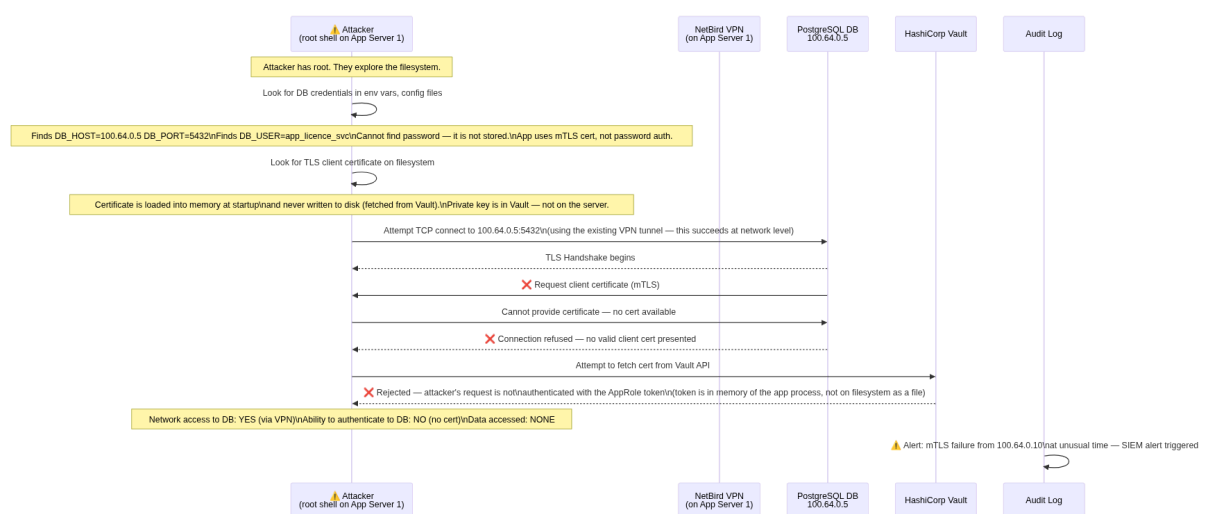
Threat: An attacker discovers the public IP of the database server and runs a port scan or attempts to connect to TCP 5432.



Outcome: The attack fails at the firewall. The attacker receives no information about what is hosted on the server. The event is not logged unless the WireGuard handshake is attempted (which is logged by NetBird management).

7.2 Scenario B: Compromised Application Server

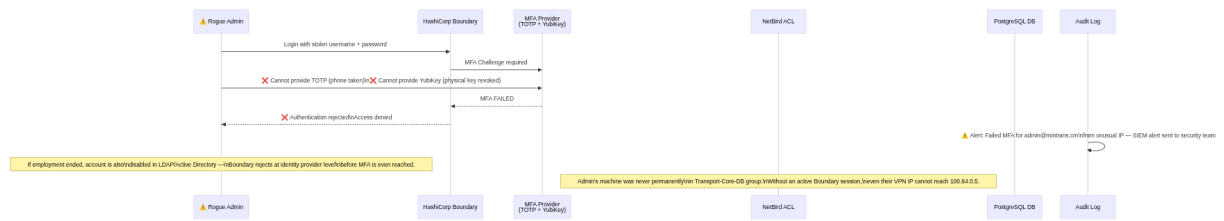
Threat: An attacker exploits a vulnerability in one of the application servers (e.g., via a dependency with a known CVE) and gains a root shell on App Server 1.



Outcome: The attacker reaches the database IP but is blocked by mTLS. No data is accessed. The failed mTLS handshake generates an alert in the SIEM. The blast radius is contained to App Server 1's own application data — no lateral movement to the database.

7.3 Scenario C: Rogue Admin with Stolen Credentials

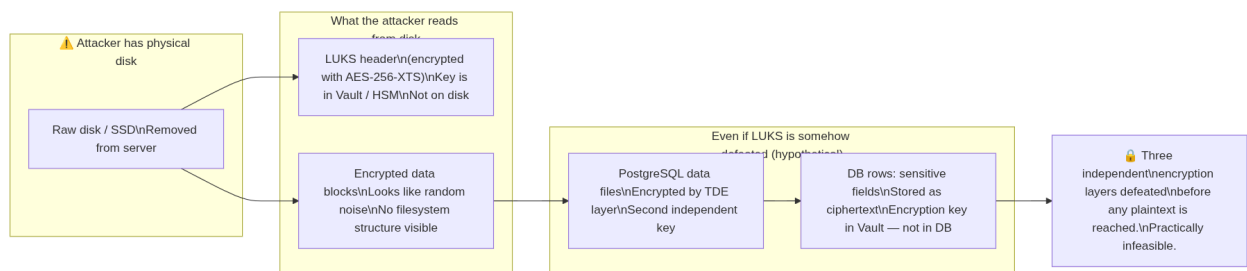
Threat: A disgruntled or compromised admin still knows their Boundary login credentials and attempts to access the production database after hours or after their employment ends.



Outcome: The rogue admin is blocked at the MFA layer. Even if they somehow bypass MFA (which requires both a software token and a physical hardware key), they would also need to be added to the NetBird DB group — which only happens through an active Boundary session — and they would still face mTLS. Three independent blockers.

7.4 Scenario D: Physical Disk Theft

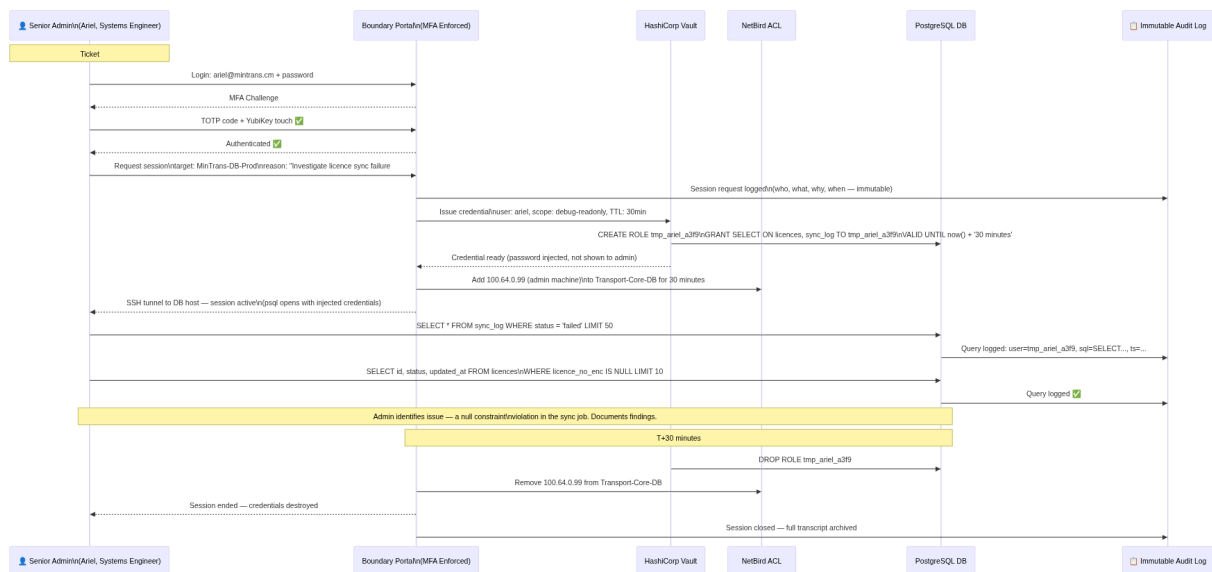
Threat: A cloud provider employee or datacenter intruder physically removes the database server's storage disk.



Outcome: The disk is useless without the LUKS master key, which never touches the disk. Three encryption layers stand between an attacker and plaintext citizen data.

7.5 Scenario E: Legitimate Admin Debug Session

Threat: None — this is the authorised workflow. Shown here to demonstrate that security controls do not obstruct legitimate operational needs.



Outcome: The admin resolves the issue within 30 minutes. The session is fully logged. No credentials persist after session end. The admin never knew the database password.

9. Limitations & Constraints

No architecture is without trade-offs. The following constraints must be understood and mitigated operationally:

#	Limitation	Operational Impact	Mitigation
L1	ALE adds per-field latency (~3–8ms per Vault Transit call)	High-frequency INSERT/SELECT throughput on encrypted fields may degrade 15–30%	Deploy Vault agent with local cache on each app server; batch encryption where possible
L2	LUKS cannot encrypt a running volume without data migration	Planned downtime required at initial setup	Schedule a maintenance window; provision new encrypted instance and migrate data
L3	30-minute TTL may interrupt long-running admin operations (e.g., large index rebuilds)	Migration jobs may fail mid-execution if credential expires	Create a separate migration Vault policy with 4-hour TTL requiring two-person approval

#	Limitation	Operational Impact	Mitigation
L4	NetBird management server is a single point of failure	If management server is down, new peer connections cannot be established (existing tunnels persist)	Run NetBird management in active-passive HA with automated failover
L5	Vault HA is mandatory — a Vault outage blocks all new app connections and all JIT access	Full application downtime if Vault cluster is unavailable	3-node Raft cluster; auto-unseal via cloud HSM (AWS KMS / Azure Key Vault)
L6	ALE prevents server-side search on encrypted fields	LIKE '%CM-12345%' queries on encrypted columns will not function	Use Vault Transform secrets engine for deterministic tokenisation of searchable fields
L7	LUKS master key loss = permanent data loss	If all Shamir shards are lost, the entire volume is permanently unrecoverable	Mandatory 3-of-5 Shamir ceremony; shards held by 5 different cleared senior officials in separate physical locations
L8	Cameroonian infrastructure maturity — reliable Tier-3+ colocation may be limited in-country	Higher latency, fewer provider redundancy options	Evaluate Tier-3 data centres in Douala and Yaoundé; use WACS/ACE submarine cables for international path redundancy
L9	mTLS certificate rotation requires coordination	Application restarts or rolling deployments needed when certificates are renewed	Vault's auto-renew capability handles rotation; applications must support SIGHUP-based cert reload without full restart
L10	Complexity increases operational overhead	The security stack (Vault HA + Boundary + NetBird + ELK) requires trained staff to operate	Invest in training for at least 3 senior engineers; maintain detailed runbooks for every operational procedure

Document ends.

For implementation support, questions on specific configuration parameters, or a Proof-of-Concept setup guide for any individual component, refer to the respective tool's official documentation or contact the Directorate of Information Systems.